

PRONTO PAYMENTS, INC.

Retrospective GRC Case Study | Real professional experience | Miami, Florida | 2008-2013

Co-founder & Director

Payments operations, third-party dependencies, merchant due diligence, transaction-security controls and payment-data flows.

REAL-WORLD EXPERIENCE

Dear Resident,

Your property manager now allows you to **pay your rent or maintenance online.**

Use **credit card, debit card or electronic check.**

Sign up now at prontopayment.com

Pronto
PAYMENT

Automatic Payments 

Notifications 

Convenient 

Business context

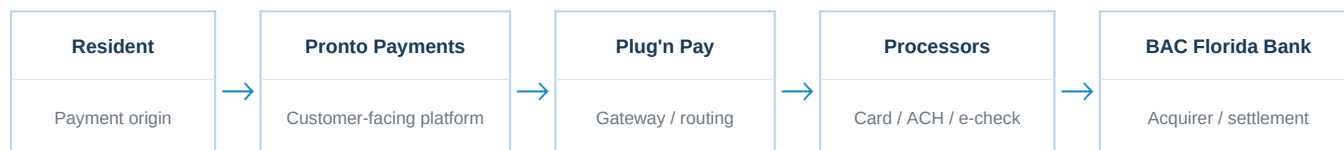
Pronto Payments was an online payment platform that enabled residents and property owners to pay rent, condominium and HOA fees, assessments and other property-related charges using credit cards, debit cards and ACH / electronic checks. The service relied on an external provider chain rather than owning the full payment infrastructure internally.

Commercial model: property managers and associations could offer the service to residents, while the payer was charged a convenience fee. Settlement and payment processing depended on external financial and technology providers.

Scope note. DORA, NIS2 and ISO/IEC 27001:2022 did not apply to Pronto Payments during its operating period. Any references to current frameworks in this case study are retrospective and show how the same risks would be analysed today; they are not claims of historical compliance.

1. Payment ecosystem and third-party dependencies

The operating model depended on an acquiring bank, a payment gateway, card and ACH processors, property-management integrations and outsourced IT support. This provider chain is the strongest link between the historical experience and my current work in ICT third-party risk.



Provider / component	Historical role
BAC Florida Bank	Acquiring bank / settlement
Plug'n Pay	Payment gateway; authorization, routing and fraud screening
Credomatic of Florida	Card processor
Smart Payment Solutions	ACH processor
Solveras / ECHO	Electronic check services
Skyline	Property-management-system integration
DNSEE	Outsourced IT / account provisioning

2. My role: operational work, modern GRC interpretation

What I did at Pronto Payments	How I analyse it today
Managed the external provider chain across gateway, processors, acquiring and outsourced IT.	ICT third-party risk, provider criticality and dependency management.
Performed merchant onboarding and due diligence.	Pre-contractual due diligence, evidence review and risk-based acceptance.
Standardised AVS, CVV2/CVC2, transaction limits and IP-based admin restrictions.	Control design and implementation: turning risk requirements into repeatable configurations.
Worked with payment and property-management data flows.	Data-flow mapping, interface risk and sensitive-data handling.

3. Key retrospective finding: concentration risk

The most important weakness visible in the historical architecture today is not primarily technical. The payment gateway was comparatively substitutable because Plug'n Pay could connect to multiple processors. The acquiring relationship was materially harder to replace. BAC Florida Bank and card processor Credomatic were also part of the same corporate group, creating a concentration point at the contractual and financial layer.

Technical layer	Contractual / financial layer
Gateway: relatively substitutable	Acquirer: harder to replace + Acquirer and processor in the same corporate group

Today I would analyse this through **provider criticality, concentration risk, substitutability, contractual dependency and exit planning**. For an EU financial entity, these themes are central to DORA Chapter V, especially Articles 28-30.

4. Retrospective control findings

Historical finding	Why it matters today
Shared portal credentials stored in clear text	Authentication information should be protected throughout its lifecycle.
Credentials sent to an external IT provider by email	Sensitive authentication information requires secure transfer and handling.
Third-party personal data retained without a documented retention rule	Retention requires a defined purpose, period, access rule and disposal process.
No documented exit strategy for the single acquiring relationship	Critical provider dependency requires contingency and executable exit planning.
Acquirer and processor concentrated within the same corporate group	Concentration risk must be assessed beyond individual supplier risk.

5. Modern control mapping

Historical area	ISO/IEC 27001:2022	DORA
External provider management	A.5.19-A.5.22	Art. 28
Provider concentration	Supplier-risk context	Art. 29
Contractual controls	A.5.20	Art. 30
Authentication information	A.5.17	ICT protection framework
Secure information transfer	A.5.14	ICT protection framework
Operational continuity / provider loss	A.5.29, A.5.30	ICT continuity / third-party risk

Interpretation rule: this mapping shows current relevance, not historical equivalence or compliance.

6. What I would formalise today

Structured third-party register	Service, data processed, criticality, supported functions, subcontractors, contractual controls, concentration dependencies and exit options.
Formal provider risk assessment cycle	Criticality -> due diligence -> security assessment -> contract review -> risk decision -> ongoing monitoring.
Acquirer exit strategy	Alternative-provider analysis, migration dependencies, termination requirements, technical changes and estimated transition time.
Credential-management requirements	Eliminate shared credentials where possible, make privileged access individually attributable and use approved secure transfer/storage methods.
Information-retention rules	Define purpose, owner, retention period, access restrictions and disposal requirements for merchant and third-party data.

7. Historical material

Original Pronto Payments marketing material from the operating period. The flyers show the customer-facing proposition and payment methods; they provide business context rather than proof of GRC controls.

Evidence basis & limitations

This case study was reconstructed from surviving corporate registration information, company agreements, merchant onboarding material, payment-provider documentation, internal procedures, configuration notes, data-integration documentation and original marketing material. Some source documents contain third-party personal or confidential information and are not published.

No transaction volumes, merchant counts, regulatory licence status or other facts for which sufficient supporting evidence has not been located are asserted here.

Positioning: My formal cybersecurity GRC specialisation came later. Pronto Payments is included because it is the real operational experience behind my current work on provider dependency, sensitive data, transaction controls, risk assessment and third-party ICT risk.

Portfolio: github.com/luckyLuke1976/cybersecurity-portfolio